

MODBUS ATTACK & DEFEND

The oldest industrial protocol still running the world — four data banks, one byte of intent, and no authentication anywhere.

Modicon 1979 · Modbus Organization spec v1.1b3
Purdue L1–L2 · HMI/SCADA ↔ PLC/RTU · serial gateways
registers are big-endian 16-bit words
Weaponised by FrostyGoop / BUSTLEBERM — Lviv, Jan 2024

Modbus has no users, no passwords and no sessions. Whoever can reach tcp/502 is the master. The only question left is which function code, against which register.

1 WHERE IT LIVES

VARIANTS

Modbus/TCP MBAP header + PDU, port 502
Modbus RTU RS-485/232 serial, CRC-16
Modbus ASCII '!' ... CRLF framing, LRC
RTU-over-TCP raw serial ADU in TCP — **no MBAP**
Modbus Security TLS on 802 — near-absent

PORTS

502/tcp Modbus/TCP — **Shodan port:502**
802/tcp Modbus/TCP Security (TLS)
no std port RTU-over-TCP on Moxa /
Lantronix / Digi gateways

Serial-to-Ethernet gateways are the soft edge: they turn a physical-access problem into a routable one. Inventory every one of them.

2 THE FOUR DATA BANKS

BANK	BITS	ACC	FUNCTION CODES
Coils	1	R/W	1 / 5 / 15
physical digital OUTPUTS — relay, valve, motor			
Discrete Inputs	1	R	2
physical digital inputs			
Input Registers	16	R	4
analog inputs / measured values			
Holding Registers	16	R/W	3 / 6 / 16 / 22 / 23
setpoints and parameters			

⚠ THE ADDRESSING TRAP

Your documentation says 40001. The wire says 0x0000.
The vendor 4xxx convention is 1-based and bank-prefixed. The PDU carries a 0-based offset within its bank. Holding register 40001 is wire address 0.
Get this wrong and you hunt the wrong register — or write to one.
32-bit and float values span TWO registers, and the word order is vendor-dependent. Never assume.

3 FRAME ANATOMY

MODBUS/TCP ADU

Trans ID	Proto ID	Length	Unit	FC	data
2 B	2 B	2 B	1 B	1 B	n B

MBAP header — 7 bytes, big-endian PDU

Trans ID echoed by the server; a compliant master increments per request.
Static across many requests = replay / injection tell.
Proto ID MUST be 0x0000. Non-zero on 502 = malformed, tunnelled or fuzzing.
Length bytes of Unit ID + PDU. **Parse by this — one TCP segment can carry several back-to-back frames.**
Unit ID slave address behind a gateway. **UNIT 0 = BROADCAST**
A write to unit 0 hits every device on the serial leg, unacknowledged.
FC | 0x80 exception response — MSB set, plus a 1-byte exception code.

RTU-OVER-TCP HAS NO MBAP

Slave Addr (1B) + FC (1B) + data + CRC-16 (2B, poly 0xA001). Your dissector will not find it on its own — Wireshark: Decode As → Modbus RTU. Miss this and a whole gateway's traffic reads as noise.

4 FUNCTION CODES — THE WEAPON RACK colour = what it does to the process

RECON READ WRITE CONTROL / DESTRUCTIVE VENDOR

READ — the baseline noise of every plant network

01	0x01	Read Coils	coils	read digital output state
02	0x02	Read Discrete Inputs	discrete in	read digital input state
03	0x03	Read Holding Registers	holding	read setpoints — FrostyGoop recon half
04	0x04	Read Input Registers	input	read measured values
07	0x07	Read Exception Status	—	serial: 8 exception bits
11	0x0B	Get Comm Event Counter	—	serial diagnostics
12	0x0C	Get Comm Event Log	—	serial diagnostics
20	0x14	Read File Record	file	config / firmware image staging
24	0x18	Read FIFO Queue	—	queue contents

RECON — unauthenticated device fingerprinting

17	0x11	Report Server ID	—	vendor + device enumeration
43	0x2B	Encap. Interface Transport	MEI 0x0E	Read Device ID: vendor, product, rev

WRITE — every one of these moves physical process

05	0x05	Write Single Coil	coils	FORCE one output ON/OFF — valve, relay, motor
06	0x06	Write Single Register	holding	one setpoint — FrostyGoop write vector
15	0x0F	Write Multiple Coils	coils	bulk output force
16	0x10	Write Multiple Registers	holding	bulk setpoint — FrostyGoop write vector
21	0x15	Write File Record	file	writes the device config store
22	0x16	Mask Write Register	holding	AND/OR read-modify-write of one register
23	0x17	Read/Write Multiple Regs	holding	read + write in ONE PDU

CONTROL — see panel 5 for the sub-function detail

08	0x08	Diagnostics	—	restart · force listen-only · clear counters
----	------	-------------	---	--

VENDOR / RESERVED

65-72	Vendor-defined range	—	legal but proprietary — baseline, do not assume
100-110	Vendor-defined range	—	anything outside these = protocol violation

5 FC 8 DIAGNOSTICS & EXCEPTIONS

FC 8 SUB-FUNCTIONS

0x00	Return Query Data	loopback echo
0x01	Restart Communications Option	DEVICE RESTART — T0816
0x02	Return Diagnostic Register	read diag register
0x03	Change ASCII Input Delimiter	framing change
0x04	Force Listen Only Mode	SILENCES THE SLAVE — DoS, T0814
0x0A	Clear Counters and Diag Register	ANTI-FORENSICS
0x0B	Return Bus Message Count	counter read
0x0C	Return Bus Comm Error Count	counter read
0x0D	Return Bus Exception Error Count	counter read
0x0E	Return Slave Message Count	counter read
0x0F	Return Slave No Response Count	counter read
0x10	Return Slave NAK Count	counter read
0x11	Return Slave Busy Count	counter read
0x12	Return Bus Char Overrun Count	counter read
0x14	Clear Overrun Counter and Flag	counter clear

EXCEPTION CODES response = FC | 0x80, then one byte

0x01	Illegal Function
0x02	Illegal Data Address
0x03	Illegal Data Value
0x04	Server Device Failure
0x05	Acknowledge
0x06	Server Device Busy
0x08	Memory Parity Error
0x0A	Gateway Path Unavailable
0x0B	Gateway Target Failed To Respond

EXCEPTIONS ARE THE LOUDEST RECON SIGNAL

Bursts of 0x01 / 0x02 across many addresses and function codes = enumeration, fuzzing or exploit probing. They ride in the RESPONSE, so you catch them even when you missed the request.

6 ATTACKER PLAYBOOK ICS Kill Chain — Stage 2

1 DISCOVER

Scan tcp/502 — Shodan port:502 still returns internet-facing PLCs daily. Behind a gateway, sweep Unit IDs 1–247 to find what is on the serial leg.

2 FINGERPRINT

FC 43 / MEI 0x0E Read Device Identification returns vendor, product code and revision. FC 17 Report Server ID does the same on serial. No session, no credentials, no trace beyond a log line.

3 MAP THE PROCESS

Walk register and coil ranges with FC 1/2/3/4. Exception 0x02 Illegal Data Address tells you exactly where the map ends. Reads are indistinguishable from the HMI's own polling — this recon is free.

4 MANIPULATE

FC 5/15 force coils, which are physical outputs. FC 6/16/22/23 write registers, which are setpoints. FC 23 reads and writes in a single PDU.

5 DISRUPT

FC 8 sub 0x04 Force Listen-Only silences a slave outright. Sub 0x01 restarts it. A broadcast write to Unit 0 hits an entire serial leg at once, unacknowledged.

6 COVER TRACKS

FC 8 sub 0x0A Clear Counters and Diagnostic Register wipes the device's own record of the errors you just caused.

WHY IT WORKS

No authentication, no encryption, no integrity, no session. Anyone on the segment is the master. FrostyGoop needed exactly three function codes — 3, 6 and 16 — and a stock Go Modbus library.

7 DEFENDER PLAYBOOK capture → parse → triage

CAPTURE

bpf: tcp port 502 trunk: (tcp port 502) or (vlan and tcp port 502)
Tap the cell/process switch. A 50-PLC 1 Hz poll loop is only ~1–5 MB/min — keep full payload.

ZEEK

modbus.log · ICSNPP: modbus_detailed.log · modbus_read_write.log
ICSNPP gives you unit_id, address, quantity and the DECODED VALUE written.

SURICATA — native modbus keyword

modbus: function [5,6,15,16]; modbus: function 8, subfunction 1;
modbus: unit 0;

WIRESHARK

modbus.func_code == 8 && modbus.diagnostic.sub_function == 4
modbus.mei == 0x0e mbtcp.unit_id == 0

TRIAGE — FIVE QUESTIONS, IN ORDER

1 Is it a write or control op? (5/6/15/16/21/22/23 · FC8 restart/listen-only/clear · unit 0)
2 Is the source a baselined master or EWS? 3 Inside a change window?
4 Does the target register match baseline? 5 Read-then-write? Write burst?
Non-baseline source on a write → ESCALATE. Notify ops BEFORE touching the process.

★ THE HIGHEST-VALUE QUERY IN OT

Modbus write function codes from a source that is not in the SCADA-master baseline.

That one query is what would have caught FrostyGoop. It needs no threat intel, no signature and no vendor feed — only an accurate list of who is allowed to write. Everything else on this poster is refinement.

8 NORMAL vs SUSPICIOUS

NORMAL

- a small, stable set of master IPs
- fixed servers and Unit IDs, regular cadence
- overwhelmingly reads — FC 1/2/3/4
- narrow, consistent register window
- transaction IDs increment; 1:1 request/response

SUSPICIOUS

- write FC from a non-baselined source — the finding
- coil force 5/15 — physical output manipulation
- write to Unit ID 0 (broadcast)
- read-then-write the same register
- FC8 restart / listen-only / clear counters
- new write target, first-seen master, off-hours
- FC17 / FC43 enumeration from a non-primary source
- non-zero protocol ID, static transaction ID
- unanswered requests (DoS) · phantom responses (spoof)
- Modbus on a non-standard port, or on a public IP

9 HARDENING

1. Modbus has no auth — the network IS the access control. Allowlist master—server pairs.
2. Never expose 502 to the internet. Check Shodan/Censys against your own ASN.
3. Segment cell/area zones; deny 502 across boundaries except named pairs.
4. Filter on function code where the firewall or OT-IDS supports it — deny writes from non-masters.
5. Block Unit ID 0 broadcast writes at the gateway.
6. Alarm on FC8 sub 0x01 / 0x04 / 0x0A — no legitimate poller sends these.
7. Baseline the register and coil map per (server, unit); alert on a new write target.
8. Where the gear supports it, move to Modbus/TCP Security (TLS on 802).
9. Inventory serial-to-Ethernet gateways — they are the quietest way in.

Top 20 Secure PLC Coding Practices · IEC 62443-3-3 · NIST SP 800-82r3

10 ATT&CK for ICS

T0846	Remote System Discovery	scanning tcp/502
T0888	Remote System Info Discovery	FC17 · FC43 MEI 0x0E
T0855	Unauthorized Command Message	any non-authorised write
T0831	Manipulation of Control	coil force FC 5/15
T0836	Modify Parameter	register write 6/16/22/23
T0806	Brute Force I/O	write bursts, range sweeps
T0816	Device Restart / Shutdown	FC8 sub 0x01
T0814	Denial of Service	FC8 sub 0x04 · flooding
T0856	Spoof Reporting Message	injected responses
T0813	Denial of Control	the FrostyGoop outcome
T0826	Loss of Availability	600+ buildings, 2 days

SEEN IN THE WILD

FrostyGoop / BUSTLEBERM — Lvivteploenergo, 22–23 Jan 2024. FC 3/6/16 against ENCO controllers.